Ticket'Tournelle : compte rendu de projet

Nov 13, 2026 · @Yuung

Ticket'Tournelle est le portail web de déclaration et de suivi des incidents techniques du Lycée La Tournelle. Il est conçu, développé, testé et prêt à être mis en production sur un serveur interne que j'ai installé et sécurisé moi-même. Ce compte rendu accompagne la restitution du Dec 4, 2026 .

Élément	Information
Cadre	Atelier de Professionnalisation, BTS SIO option SLAM, 2e année, 2026-2027
Établissement	Lycée La Tournelle, La Garenne-Colombes
Maîtrise d'ouvrage	M. Lorant-Raze (chef d'établissement), M. Chamayou (DDF du pôle industriel)
Équipe technique	Yuung Kansietoko
Version présentée	v1.0.0-rc1 (version candidate à la mise en production)

1. Le contexte et la problématique

Le lycée compte plus de 200 personnels, mais ses incidents techniques arrivent par cinq canaux différents : un fichier Excel partagé, un lien Drive, des SMS, des notes vocales WhatsApp et des appels directs aux référents numériques. Les demandes se perdent, le traitement prend du retard, la direction n'a aucun chiffre et les référents sont débordés.

La problématique posée par la maîtrise d'ouvrage : comment permettre à un établissement public de plus de 200 personnels de déclarer, suivre et traiter ses incidents de manière centralisée, traçable et mesurable ?

La réponse est un portail à trois rôles. Le personnel déclare un incident et suit sa résolution. Le technicien, ou référent numérique, traite une file de tickets. L'administrateur gère les comptes et consulte les indicateurs.

Le MOA impose neuf contraintes. Voici où en est chacune :

Contrainte	État	Preuve
C1 Un compte nominatif par personnel	Respectée	Connexion par compte, comptes désactivés et jamais supprimés

Contrainte	État	Preuve
C2 Interface et notifications en français et en anglais	Respectée	300 textes traduits, un test échoue si une traduction manque
C3 Serveur web interne installé et administré par l'équipe	Respectée	VM Debian 13 installée par script, 48 tests du serveur au vert
C4 Sécurité selon les bonnes pratiques, choix prouvés	Respectée	Dossier sécurité : chaque mesure, sa référence et le test qui la prouve
C5 Comptes administrateurs selon les recommandations de l'ANSSI	Partielle	Comptes nominatifs, séparés, journalisés ; la double authentification reste à faire
C6 Pilotage avec Trello, tenu à jour	Respectée	Tableau en 10 phases, chaque carte terminée porte ses preuves
C7 Espace collaboratif pour les documents	Respectée	Dossier Google Drive organisé en 10 rubriques
C8 Un livrable avec une documentation d'utilisation	Respectée	Guide des personnels illustré, livrable rassemblé dans le Drive
C9 Démarche méthodique, étapes validées	En attente	Il manque la validation écrite du cahier des charges par le MOA

2. La solution et les outils utilisés

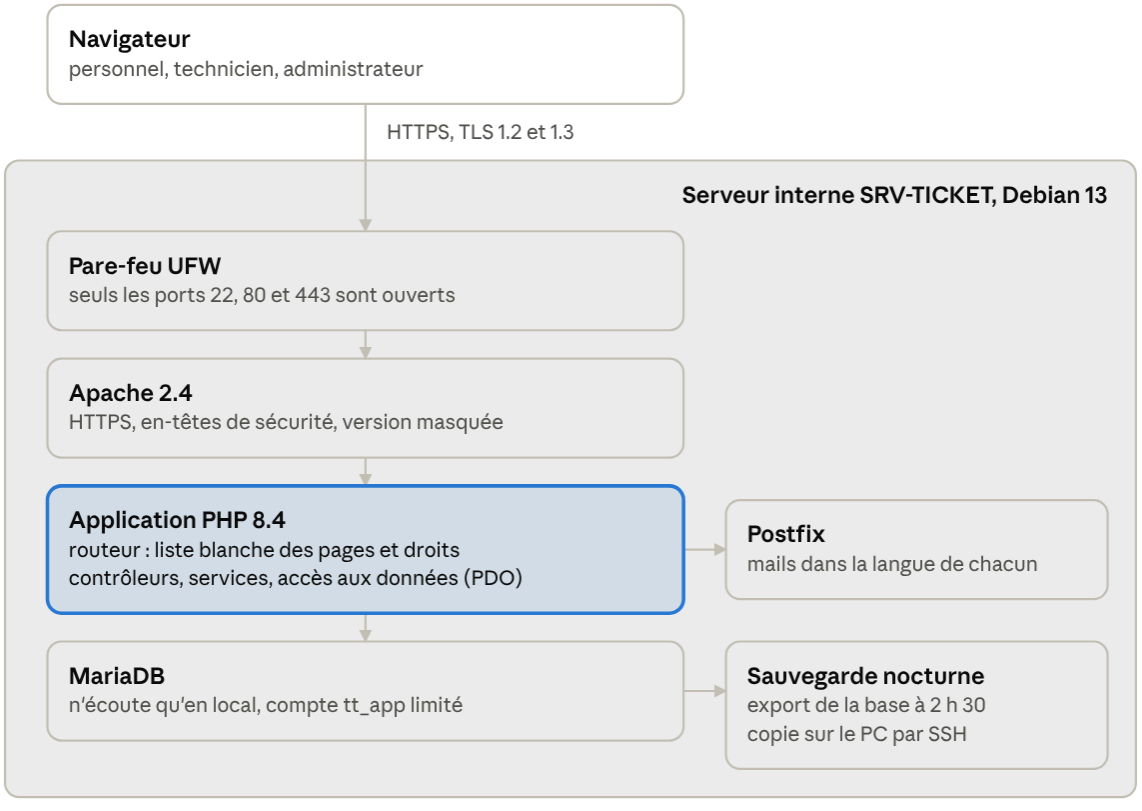
La solution est une application PHP sans framework, hébergée sur un serveur Debian que j'ai installé et durci par script, avec une base MariaDB. Sans framework, je peux expliquer et prouver chaque mesure de sécurité une par une.

Brique	Choix	Pourquoi
Système	Debian 13, sans interface graphique, compte root désactivé	Libre, stable, mises à jour de sécurité automatiques ; contrainte C3
Serveur web	Apache 2.4, HTTPS en TLS 1.2 et 1.3 uniquement	Identifiants et tickets ne circulent jamais en clair
Langage	PHP 8.4, organisé en routeur, contrôleurs, services, accès aux données et gabarits	Langage du BTS SLAM ; Argon2id, PDO et sessions fournis par PHP

Brique	Choix	Pourquoi
Base de données	MariaDB : 16 tables, 5 vues, clés étrangères et contraintes	Intégrité des tickets garantie par la base elle-même
Accès à la base	PDO, requêtes préparées, compte tt_app limité à lire et écrire des lignes	Bloque l'injection SQL ; moindre privilège
Protection du serveur	Pare-feu UFW (ports 22, 80, 443), Fail2ban, SSH par clé	Réduire la surface d'attaque
Notifications	Postfix local, mails dans la langue du destinataire	Prêt pour le relais SMTP du lycée
Sauvegardes	Export de la base chaque nuit, 14 jours gardés, copie sur le PC, restauration testée	Risque « perte de données » de l'analyse des risques

Les outils de travail : VS Code pour le code, Git et un dépôt GitHub privé pour l'historique, MAMP pour développer en local, VMware Workstation pour le serveur, Trello pour le pilotage, Google Drive pour les documents, Playwright pour tester dans un vrai navigateur et sqlmap pour les tests d'injection SQL.

Chaque requête passe trois contrôles avant d'atteindre la base



architecture du serveur interne · 4 couches, 2 services annexes

Une demande ne touche la base qu'après le pare-feu, Apache et le routeur, qui vérifie la page et le rôle ; la base n'est jamais joignable depuis le réseau.

3. La méthode

Le projet est piloté en 10 phases sur Trello, une carte par mission, et une carte n'est terminée que lorsque sa preuve existe. Les phases suivent le cycle d'un projet réel : cahier des charges, pilotage, serveur, base de données, développement, sécurité, tests, documentation, mise en production et restitution.

Chaque mission suit le même déroulé :

1. une branche Git dédiée, pour ne jamais casser la version qui fonctionne ;
2. le code, puis les tests automatiques de la mission ;
3. la même suite lancée sur deux environnements : un environnement Linux et mon PC avec MAMP ;
4. la fusion dans la branche principale et l'envoi sur GitHub ;
5. la carte Trello : cases cochées, commentaire avec les résultats chiffrés, liens vers les fichiers de preuve, pastille verte ;
6. la mise à jour de la documentation.

Le projet a été vérifié trois fois. La première vérification lance toutes les suites sur deux environnements différents. La deuxième est une relecture indépendante du code, par un relecteur qui ne l'avait pas écrit : elle a relevé 11 défauts, tous corrigés. La troisième relance tout dans un environnement neuf, trois fois de suite, et contrôle que chaque case cochée du Trello a une preuve.

Autour du code, trois outils gardent la trace du projet :

- le dépôt Git, avec son historique de commits ;
- l'espace Google Drive, rangé en dix rubriques ;
- le registre des échanges avec le MOA. Toute question y est notée avec sa réponse, et toute évolution du besoin n'est appliquée qu'après une validation écrite.

4. La démonstration

La démonstration dure 10 minutes : elle suit un ticket de sa déclaration à sa clôture, en passant par les trois rôles, puis montre deux protections en direct.

Minute	Rôle	Ce que je fais	Ce que le jury voit
0	Personnel	Je me connecte avec un compte nominatif et je passe l'interface en anglais, puis en français	Comptes nominatifs et bilingue (C1, C2)
1	Personnel	Je déclare « Vidéoprojecteur en panne, salle B101 » avec une photo	Contrôle des champs, photo acceptée seulement si c'est une vraie image
3	Technicien	J'ouvre la file, je prends le ticket, j'ajoute une note interne, je le passe en cours puis résolu	File triée par priorité, transitions contrôlées, note invisible pour le demandeur
5	Personnel	Je vois la notification, je lis l'historique et je clôture	Traçabilité complète, mail dans la langue de chacun
6	Administrateur	J'ouvre le tableau de bord, je crée un compte par lien d'activation, j'affiche le journal de sécurité	Indicateurs pour la direction, aucun mot de passe envoyé par mail
8	Sécurité	Je tape 5 mauvais mots de passe, puis j'ouvre l'adresse d'un ticket qui n'est pas le mien	Compte verrouillé 15 minutes ; réponse « introuvable », aucune fuite
9	Conclusion	Je montre le Trello et les résultats des tests	Projet piloté et prouvé

La démonstration se fait sur le serveur interne, avec les comptes du jeu d'essai, jamais avec de vraies données. Si le réseau tombe, le même scénario tourne sur mon PC avec MAMP. Dernier recours : les captures d'écran du parcours, en français, en anglais et sur téléphone, prises automatiquement par les tests.

5. Les tests

Plus de 520 vérifications automatiques passent toutes, sur deux environnements différents, et 23 anomalies ont été trouvées puis corrigées. Chaque test se relance en une commande sur le PC (lancer-tests.bat).

Famille de tests	Ce qu'elle vérifie	Résultat au 13/11/2026
Unitaires et fonctionnels	Droits par rôle, traductions, jeton CSRF, échappement, photos, cycle de vie, notifications, administration, sur un vrai serveur PHP et une base de test	285/285, trois passages de suite, et 285/285 sur MAMP
Parcours dans un vrai navigateur (Playwright)	Les trois rôles en français, en anglais et sur téléphone ; aucune erreur JavaScript, aucune violation de la CSP, un libellé par champ	130/130
Connexion	Mots de passe, verrouillage, inactivité, déconnexion	30/30
Serveur	Base (24), services, HTTPS, pare-feu, SSH, droits des fichiers, messagerie (48), restauration d'une sauvegarde (9)	81/81, sur le serveur après le déploiement de la v1.0.0-rc1

Les tests de sécurité rejouent les attaques courantes. sqlmap n'a trouvé aucun paramètre injectable. Les attaques XSS, CSRF, l'accès direct par URL et la force brute sont rejoués par les tests automatiques, y compris 12 essais de connexion envoyés au même instant. Le scan OWASP ZAP et Nikto reste à lancer depuis le PC, sur le serveur de recette uniquement.

Les 23 anomalies sont notées dans un registre, chacune avec sa cause, sa correction et un test qui empêche son retour : 1 bloquante, 10 majeures et 12 mineures. Deux exemples parlent d'eux-mêmes :

- **BUG-011 :** en envoyant des essais de connexion en parallèle, on pouvait tester 22 mots de passe au lieu de 5. La base réserve désormais chaque essai de façon atomique.
- **BUG-021 :** quand la base et PHP ne sont pas réglés sur le même fuseau horaire, un verrou de 15 minutes paraissait déjà expiré. Chaque connexion à la base impose maintenant l'heure de PHP.

6. Les fiches

Chaque partie du projet a sa fiche, écrite pour son lecteur et rangée à la fois dans le dépôt Git et dans l'espace collaboratif.

Fiche	Pour qui	Ce qu'elle contient
Fiche de situation professionnelle	Le jury du BTS	Besoin, réalisation, compétences des trois blocs avec leur preuve
Guide des personnels	Professeurs et personnels	Se connecter, signaler un incident, suivre ses tickets, choisir la langue, questions fréquentes, avec captures
Guide administrateur	L'administrateur	Serveur, journaux, comptes, revue trimestrielle, référentiels, tâches de nuit
Fiche d'installation du serveur	L'équipe technique	La VM pas à pas, chaque commande expliquée
Procédure de déploiement	L'équipe technique	La commande unique, la liste de contrôle et le retour arrière
Sauvegarde et restauration	L'équipe technique	Sauvegarde, copie sur le PC, test et restauration réelle
Dossier sécurité	MOA et jury	Chaque mesure, sa menace, sa référence OWASP, ANSSI ou CNIL, et sa preuve
Matrice des droits	MOA et développeurs	Qui peut faire quoi, rôle par rôle
Cahier de recette	MOA	Un cas par user story et par règle de gestion, avec son résultat
Registre des anomalies	Équipe et jury	Les 23 anomalies, leur cause, leur correction, leur test
Registre des échanges avec le MOA	MOA et équipe	Questions, réponses, décisions et validations
Guide de compréhension	Moi, pour l'oral	Le code expliqué ligne par ligne, une quarantaine de questions du jury avec leurs réponses

7. Conclusion

Le portail atteint les six objectifs du cahier des charges, et il ne lui manque que des étapes qui dépendent du lycée pour être mis en production.

Objectif du cahier des charges	Résultat
Centralisation	Toutes les demandes passent par un seul portail
Traçabilité	Chaque action est inscrite dans l'historique du ticket, dans la même transaction
Suivi	Le demandeur voit le statut et reçoit une notification à chaque étape
Traitement	Les techniciens ont une file triée, des notes internes et un cycle de vie contrôlé
Pilotage	Le tableau de bord donne les volumes, le temps moyen de résolution et les salles à problèmes
Sécurité	Chaque mesure est prouvée par un test ; sqlmap ne trouve rien à injecter

Ce projet m'a appris à penser à la fois en développeur et en administrateur. Une fonctionnalité n'est finie que lorsqu'un test la prouve, et un serveur n'est fiable que lorsque son installation se rejoue à l'identique. Les anomalies les plus instructives sont venues des vérifications croisées : un deuxième environnement, un deuxième regard.

Limites connues et suites à donner :

- obtenir la validation écrite du cahier des charges et faire la recette avec deux professeurs et un référent numérique ;
- brancher le relais de messagerie du lycée, dont les paramètres sont demandés au MOA ;
- ajouter la double authentification des administrateurs, recommandée par l'ANSSI (code à usage unique) ;
- lancer le scan OWASP ZAP et Nikto sur le serveur de recette ;
- déployer la version finale, créer les vrais comptes et installer la VM sur l'hyperviseur du lycée.

Pistes d'évolution :

- la connexion avec les comptes de l'ENT ou de l'annuaire du lycée ;
- un inventaire du matériel relié aux tickets ;
- des statistiques par période scolaire.

Annexes

- Tableau Trello du projet, en 10 phases, avec les preuves sur chaque carte
- Espace collaboratif Google Drive : cahier des charges, maquettes, livrables
- Dépôt GitHub du code, privé, ouvert aux professeurs sur invitation
- Fiche de situation professionnelle
- Dossier sécurité
- Cahier de recette
- Registre des anomalies
- Guide des personnels
- Support de présentation